

SecureGate 2FA Knowledge Base

Technical specifications, compliance, and frequently asked questions

This document is the retrieval corpus for the SecureGate public-site assistant. Answers to prospect questions must be grounded in the sections below. Do not invent certifications, algorithms, SLAs, or sandbox policy that are not written here.

1. Product overview

SecureGate 2FA is a two-factor authentication platform for regulated teams. After a password or SSO assertion succeeds, the user must prove possession of a registered authenticator. The default factor is a time-based one-time password (TOTP). Enterprise customers may also register WebAuthn / FIDO2 security keys and passkeys. The product is designed so auditors can map controls to RFC 6238, SOC 2 Type II, HIPAA, and GDPR without a custom questionnaire for every deal.

2. TOTP algorithm (RFC 6238)

One-time passwords implement TOTP as defined in RFC 6238, which extends HOTP from RFC 4226. The moving factor is time, not a counter. Codes are derived as $\text{HMAC}(K, T)$ where $T = \text{floor}((\text{UnixTime} - T_0) / X)$, $T_0 = 0$, and the time-step X is 30 seconds. Default display is 6 digits; 8 digits are configurable. HMAC-SHA1 is the default so Google Authenticator, Authy, and 1Password work out of the box. HMAC-SHA256 and HMAC-SHA512 are supported on the Enterprise plan.

3. Clock drift, replay, and lockout

Phones drift. The verifier therefore accepts a validation window of ± 1 time-step: the previous, current, and next 30-second step. Each accepted code is recorded and cannot be replayed within its validity window. Repeated failures trigger exponential back-off. After 5 consecutive invalid codes the authenticator is locked until an administrator or a recovery flow resets it.

4. Secret generation and storage

Shared secrets are generated with a CSPRNG (160-bit minimum) and provisioned to the authenticator as an `otpauth://` URI encoded in a QR code. After enrollment the secret is never returned by any API. Secrets are encrypted at rest with AES-256-GCM using per-tenant keys stored in a FIPS 140-2 Level 3 HSM. All traffic uses TLS 1.2+.

5. Compliance: SOC 2 Type II, HIPAA, GDPR

SOC 2 Type II covers Security, Availability, and Confidentiality. The audit is annual, run by an independent AICPA-accredited CPA firm over a 12-month observation period. The report is available under NDA via the Trust Center. HIPAA: SecureGate supports covered entities and business associates and signs a Business Associate

Agreement (BAA) on the Enterprise plan. Logs that may contain ePHI are encrypted at rest and in transit, retained per customer policy, and access is role-restricted with audit trails. GDPR: SecureGate is a data processor, offers a DPA with EU Standard Contractual Clauses, and can pin residency to Frankfurt (eu-central). Access and erasure requests are fulfilled within 30 days.

6. Plans and sandbox credentials

MID-MARKET (under 500 employees) is self-serve: automated onboarding, SAML SSO, standard support, 99.9% uptime SLA. ENTERPRISE (500 or more employees) adds a dedicated account executive and solutions engineer, HIPAA BAA, custom data residency, SCIM, 24/7 premium support, and a 99.99% uptime SLA. Sandbox API keys are issued only to verified corporate email domains. Gmail, Yahoo, Outlook, and other public webmail are rejected. Keys are prefixed `sbx_test_`, expire after 14 days, are limited to 100 requests per minute, and cannot send real SMS or push.

7. Integrations and factors

Identity providers: Okta, Microsoft Entra ID (Azure AD), Auth0, Ping Identity, Keycloak, and any SAML 2.0 or OIDC IdP. APIs: REST and gRPC, with SDKs for Python, Node.js, Go, and Java. Webhooks report enrollment and verification. TOTP apps are the primary factor. SMS OTP is not used in sandbox and is discouraged in production because of SIM-swap risk. WebAuthn / FIDO2 keys and passkeys are available on Enterprise as a phishing-resistant factor.

8. Frequently asked questions

Q1. What is SecureGate two-factor authentication?

Topic: overview | id: what-is-2fa

A1. SecureGate 2FA is a second authentication factor on top of a password or SSO. After the primary factor succeeds, the user proves possession of a registered authenticator by entering a time-based one-time password (TOTP). The verifier accepts the code only inside a 30-second time-step window, then records it so it cannot be replayed.

Q2. Which OTP algorithm and time-step does SecureGate implement?

Topic: totp | id: totp-rfc6238

A2. SecureGate implements TOTP as defined in RFC 6238, which extends HOTP from RFC 4226. Codes are HMAC(K, T) where $T = \text{floor}((\text{UnixTime} - T_0) / X)$, $T_0 = 0$, and the time-step X is 30 seconds. Default codes are 6 digits (8 digits configurable). HMAC-SHA1 is the default for authenticator-app compatibility; HMAC-SHA256 and HMAC-SHA512 are available on Enterprise.

Q3. How does SecureGate handle authenticator clock drift and replayed codes?

Topic: totp | id: clock-drift

A3. The verifier accepts a window of +/-1 time-step (previous, current, and next 30-second step) to tolerate device clock skew. Each accepted code is recorded and cannot be replayed inside its validity window. Five consecutive invalid codes trigger exponential back-off and logout.

Q4. How are TOTP shared secrets generated, provisioned, and stored?

Topic: security | id: secret-storage

A4. Shared secrets are generated with a CSPRNG (160-bit minimum), provisioned via otpauth:// QR codes, encrypted at rest with AES-256-GCM using per-tenant keys in a FIPS 140-2 Level 3 HSM, and never returned by any API after enrollment. All traffic uses TLS 1.2+.

Q5. Is SecureGate HIPAA compliant, and will you sign a BAA?

Topic: compliance | id: hipaa

A5. SecureGate supports HIPAA-regulated customers (covered entities and business associates). A Business Associate Agreement (BAA) is signed on the Enterprise plan. Authentication logs that may contain ePHI are encrypted at rest and in transit, retained per customer policy, and access is restricted by role with full audit trails.

Q6. Do you have a SOC 2 report, which type, and how often is it audited?

Topic: compliance | id: soc2

A6. SecureGate holds a SOC 2 Type II attestation covering the Security, Availability, and Confidentiality Trust Services Criteria. The audit is performed annually by an independent AICPA-accredited CPA firm over a

12-month observation period. The latest report is available to prospects under NDA through the Trust Center.

Q7. How does SecureGate handle GDPR and EU data residency?

Topic: compliance | id: gdpr

A7. SecureGate acts as a data processor and offers a Data Processing Agreement (DPA) with EU Standard Contractual Clauses. EU customers can pin data residency to the Frankfurt (eu-central) region. Data-subject access and erasure requests are fulfilled within 30 days, and a public sub-processor list is maintained.

Q8. What is the difference between MID-MARKET and ENTERPRISE plans?

Topic: sales | id: plans

A8. MID-MARKET (under 500 employees) is self-serve with automated onboarding, SAML SSO, standard support, and a 99.9% uptime SLA. ENTERPRISE is 500 employees or more and includes a dedicated account executive and solutions engineer, HIPAA BAA, custom data residency, SCIM provisioning, 24/7 premium support, and a 99.99% uptime SLA. A company of 1,200 employees is ENTERPRISE.

Q9. Who can receive sandbox API credentials, and what are the limits?

Topic: sales | id: sandbox

A9. Sandbox API keys are issued only to verified corporate email domains. Public webmail (Gmail, Yahoo, Outlook, and similar) is not eligible. Keys are prefixed `sbx_test_`, expire after 14 days, are rate limited to 100 requests per minute, and cannot send real SMS or push notifications.

Q10. Which identity providers and APIs does SecureGate integrate with?

Topic: integrations | id: integrations

A10. SecureGate integrates with Okta, Microsoft Entra ID (Azure AD), Auth0, Ping Identity, Keycloak, and any SAML 2.0 or OIDC identity provider. REST and gRPC APIs are available, with SDKs for Python, Node.js, Go, and Java. Webhooks report enrollment and verification events.

Q11. Does SecureGate use SMS one-time codes as the primary 2FA factor?

Topic: security | id: sms-vs-totp

A11. TOTP authenticator apps are the primary second factor. SMS one-time codes are not used in the sandbox and are discouraged in production because of SIM-swap risk. Enterprise customers who still require SMS must enable it explicitly and accept a lower assurance level than TOTP or WebAuthn.

Q12. Do you support WebAuthn / FIDO2 as a phishing-resistant factor?

Topic: security | id: webauthn

A12. Enterprise plans support WebAuthn / FIDO2 security keys and passkeys as a phishing-resistant factor alongside TOTP. Users may register multiple authenticators. TOTP remains the default for authenticator-app compatibility during rollout.